

Table of Contents

Cisco Secure Workload — BSI Cloud Computing Compliance Criteria Catalogue (C5)

Reference Design | Cloud Service Providers and Cloud-Hosted Workloads Serving German Federal / Public-Sector Customers

Version: 1.0

Framework: Cloud Computing Compliance Criteria Catalogue (C5), Federal Office for Information Security (Bundesamt für Sicherheit in der Informationstechnik / BSI). C5:2020 is the published catalogue at the time of writing.

Use Case: Cloud workload segmentation evidence, operational security (OPS) evidence, communication security (KOS) evidence, identity & access management (IDM) at the workload-to-workload layer, asset management (AM) evidence, incident management (SIM) forensic input, and assessor evidence preparation

Framework version note. This reference design references C5:2020. BSI may publish revisions; validate the catalogue version against the customer's assessment scope. C5 distinguishes between **Basic Criteria** and **Additional Criteria** (the latter expanding evidence requirements). This reference design references **C5 topic areas by name** and a few well-known area abbreviations (e.g. AM, IDM, KRY, OPS, KOS, SIM, BCM). Specific criterion numbering may vary across catalogue revisions — confirm against the version under assessment.

CSW UI navigation note. Cisco does not yet publish C5-specific CSW UI navigation; framework-specific paths are on the product roadmap. This reference design describes CSW *capabilities* and the *evidence artifacts* they produce.

Reader's Guide

Who this is for. Cloud service providers (CSPs) and customers operating cloud-hosted workloads that serve German federal or public-sector customers, or any customer that contractually requires C5 evidence; CISO function, cloud operations lead, and the team preparing the C5 attestation (Type 1 or Type 2) report with an external auditor.

Questions this reference design helps you answer:

- *Can I evidence cloud-workload asset management (AM) at the workload layer?*
- *Can I evidence segmentation between cloud customer tenants and between cloud environments (KOS)?*

- *Can I evidence operational security controls — monitoring, vulnerability management, configuration baselines (OPS)?*
- *Can I evidence workload-to-workload access privileges aligned with the identity layer (IDM)?*
- *Can I produce forensic-quality evidence for security incident management (SIM)?*

What you'll need. Cloud asset inventory across all relevant cloud accounts / subscriptions, tenant separation model, customer scope agreements, vulnerability management process, configuration baseline definitions, incident management reference design, and the C5 assessor's evidence template.

Where to start. Sections 1–4 if you are scoping; 5–7 if you are designing and simulating policy; 9–10 if you are preparing the auditor evidence pack within the next quarter.

CSW primer — if you are new to Cisco Secure Workload

Cisco Secure Workload (CSW) is a **workload protection platform**. A lightweight **agent** on each server/VM/container observes processes and network flows; **cloud connectors** add AWS/Azure/GCP inventory where agents are not deployed.

CSW term	Meaning	Why compliance teams care
Scope	Logical boundary (CDE, PHI zone, CUI enclave)	Defines the systems you must prove are isolated
Label / filter	Tag or query assigning workloads to scopes	Automates scope membership — reduces drift
ADM	Application Dependency Mapping from observed traffic	Live network/data-flow diagram for assessors
Workspace	Policy container for one scope or application	Where allow/deny rules are authored
Monitor → Simulation → Enforce	Safe rollout sequence	Simulation = change-board evidence before blocking traffic
Denied Connections	Log of flows blocked by policy	Primary proof that enforcement operates

Console areas: Investigate (inventory, flows, vulns) · Defend/Segmentation (policy) · Manage (agents) · Platform (connectors) · Administration (audit log)

Read next: [Compliance evidence playbook](#) (full step-by-step) · [About CSW](#) (platform intro)

Universal evidence workflow

Execute these phases for **this framework's** compliance boundary. Map exports to control IDs in the **Reporting & Evidence** section below.

Phase	Goal	Key CSW actions	Typical duration
1 — Coverage	Every in-scope workload in CSW	Install agents/connectors ; apply compliance labels; create scope	Days 1–10
2 — Baseline	Machine-generated flow map	Run ADM ≥ 2 weeks; export clusters; app-owner signoff	Days 11–28
3 — Policy	Designed isolation before enforce	Build workspace; Simulation mode; fix false positives	Days 29–45
4 — Operate	Continuous proof between audits	Enforce; quarterly export pack; ADM refresh every 90 days	Ongoing

Phase 1 checklist (coverage)

- ☐ In-scope host list reconciled to CSW Inventory (100% or documented exceptions)
- ☐ Labels applied: `compliance:<framework>`, `data:<classification>`, `env:<tier>`
- ☐ CSW scope created matching compliance boundary
- ☐ **Export:** inventory CSV + agent status screenshot

Phase 2 checklist (baseline)

- ☐ ADM running on compliance scope for full business cycle (≥ 2 weeks)
- ☐ Unexpected flows documented (shadow IT, vendor egress, scope creep)
- ☐ App owners signed cluster-to-application mapping
- ☐ **Export:** ADM diagram + flow samples with process context

Phase 3 checklist (policy)

- ☐ Default-deny posture defined for sensitive scope
- ☐ ADM-imported rules refined; Simulation run ≥ 1 week
- ☐ Change tickets for false-positive fixes; exception register updated
- ☐ **Export:** policy export + simulation report

Phase 4 checklist (operate)

- ☐ Enforcement enabled on pilot scope; negative test recorded in Denied Connections
- ☐ Quarterly pack: inventory, policy, denies, vulns, audit log (see playbook)
- ☐ SIEM integration verified (sample events)
- ☐ **Export:** enforcement screenshot + quarterly binder

What CSW evidence does not replace

Physical access, HR/training records, encryption key management, signed BAAs/vendor contracts, formal pen tests, and assessor attestation still require separate programmes. CSW addresses the **workload-resident** slice: segmentation, flows, process context, vuln reachability, and change drift.

CSW effectiveness for this framework

- Cloud service assurance with tenant boundary enforcement
- Cloud communication security evidence
- Vulnerability and incident artefacts for C5 auditors

Compared to manual programmes: static diagrams and annual firewall samples age immediately; CSW ties evidence to **live workload behaviour** and produces queryable exports on demand — supporting "operating effectively" language in PCI v4.0, SOC 2 CC7, and HIPAA risk analysis.

1. Overview

C5 is the BSI catalogue for cloud-service security. It is structured around topic areas (Bereiche), each containing multiple criteria. The catalogue is typically used as the basis of a C5 attestation report performed by an external auditor under ISAE 3000 / IDW PS 860, very similar in style to a SOC 2 Type 2 report.

CSW can support **technical evidence** for the workload-, network-, segmentation-, telemetry-, vulnerability-, and incident-related criteria of C5: Asset Management (AM), Identity and Access Management at the workload-to-workload layer (IDM), Operational Security (OPS), Communication Security (KOS), and Security Incident Management (SIM). CSW does **not** replace organisational, physical, contractual, supplier, or personnel controls — and it does not replace cryptography (KRY) or identity-lifecycle controls.

C5 Topic Areas and CSW Relevance

C5 topic area (Bereich)	CSW relevance
Organisation of Information Security (OIS)	Out of scope (governance)
Personnel (HR)	Out of scope

C5 topic area (Bereich)	CSW relevance
Asset Management (AM)	Workload inventory; scope + label evidence; reachability
Physical Security (PS)	Out of scope
Operations (OPS)	Continuous monitoring, vulnerability + reachability, configuration baseline
Identity and Access Management (IDM)	Workload-to-workload allowlist (complements identity layer)
Cryptography and Key Management (KRY)	Plaintext-flow detection on regulated paths (detection only)
Communication Security (KOS)	Workload-level segmentation; ADM-derived allowlist; policy workspace
Portability and Interoperability (PI)	Out of scope
Procurement, Development and Modification (DEV)	Out of scope for code-level controls; CSW shows reachability of dev / build paths
Control and Monitoring of Service Providers (SP)	Outbound flow visibility to service-provider endpoints
Security Incident Management (SIM)	Forensic flow + process telemetry
Business Continuity (BCM)	Approved flow baseline as one input to recoverability evidence
Compliance (COM)	Periodic evidence pack inputs
Investigation (INQ)	Forensic flow / process telemetry

2. Pre-Deployment Checklist

- ☐ CSW cluster provisioned
- ☐ Cloud accounts / subscriptions enumerated; CSW cloud connectors prepared
- ☐ Sensor compatibility verified for representative Linux / Windows cloud workloads
- ☐ Tenant separation model documented (single-tenant per customer? multi-tenant with logical isolation?)
- ☐ Stakeholders identified: CISO, Cloud Operations Lead, Auditor liaison, Service Provider Manager
- ☐ Evidence retention period agreed with the auditor (typically 12 months for Type 2)

3. Phase 1 — Sensor & Connector Deployment (Days 1–5)

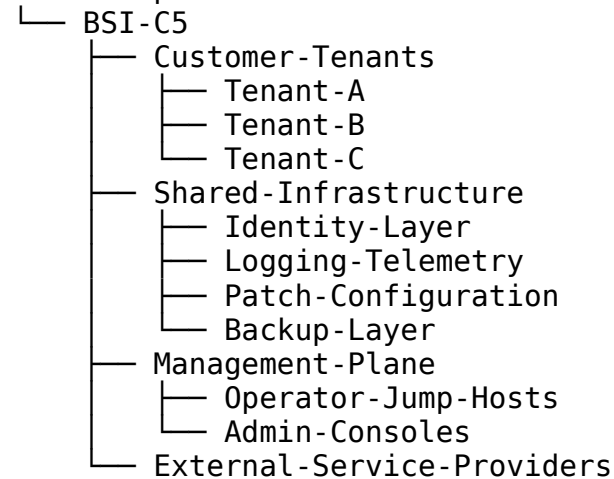
- Connect all in-scope cloud accounts / subscriptions as read-only CSW cloud connectors
- Install software sensors on representative cloud workloads in monitoring mode
- Day-1 labels: tenant, customer, environment, data_class, service_offering, owner, compliance=bsi-c5

- Maintain a cannot-instrument register for managed PaaS / SaaS dependencies; this register is evidence
 - Retain Phase-1 sensor inventory baseline
-

4. Phase 2 — Scope, Tenant Boundary, and Asset Management (Days 6 –10) — supports AM, KOS

4.1 Suggested Scope Architecture

Root Scope



4.2 Inventory Filters

Filter: Customer-Tenant-Membership

- Tag (from cloud tags): tenant = <tenant-id>
- Cloud account / subscription matches tenant assignment

Filter: Shared-Infrastructure-Candidates

- Tag: service_offering = shared | platform
- Reach: serves multiple tenants

Filter: Management-Plane-Candidates

- Listening port: 22, 3389, 443 (admin endpoints)
- Tag: purpose = management-plane

4.3 Labeling Strategy

Label key	Example values	Why it matters for C5
tenant		Anchors KOS tenant-separation evidence
customer		Maps workloads to customer contractual scope
environment	production, staging, dev	Required for

Label key	Example values	Why it matters for C5
		environment separation evidence
data_class	customer, internal, public	Data-handling evidence
service_offering	, shared, platform	Maps workloads to documented service offerings
owner		Accountability
compliance	bsi-c5	Filters CSW evidence to C5 scope

Inventory + scope + label evidence = AM evidence at the workload layer.

5. Phase 3 — Application Dependency Mapping (Days 11–21)

Run ADM for each scope across a 2-week-minimum window. Document, per cluster:

Question	C5 topic area
Do Tenant-A workloads ever reach Tenant-B workloads?	KOS (tenant separation)
Are flows from Management-Plane into Customer-Tenants restricted to documented admin paths?	IDM (privileged access)
Are database flows plaintext?	KRY (detection)
Which Customer-Tenants reach External-Service-Providers?	SP (sub-service-provider control)
Are unexpected lateral flows present inside Shared-Infrastructure?	OPS / SIM

Use ADM to confirm / correct tenant, service_offering, and data_class labels.

6. Phase 4 — Policy Development (Days 22–35) — supports KOS, IDM, OPS

6.1 C5-Aligned Policy Framework

Absolute policies (tenant separation; the heart of KOS for multi-tenant CSPs):

DENY Tenant-A cross-tenant flow)	→ Tenant-B	(no
DENY Tenant-B	→ Tenant-A	(no

cross-tenant flow)
 DENY Customer-Tenants → Internet (no
 direct internet egress unless service-offering-defined)
 DENY Corporate-IT → Customer-Tenants
 (admin only via Management-Plane)

Allowlist policies (least privilege):

ALLOW Tenant-A-Channel → Tenant-A-DB
 tcp/<db-port-tls>
 ALLOW Customer-Tenants → Shared-Infrastructure
 tcp/443 (platform services only)
 ALLOW Operator-Jump-Hosts → Customer-Tenants
 tcp/22, tcp/3389
 ALLOW Customer-Tenants → Logging-Telemetry
 tcp/443

Catch-all:

LOG Any → Customer-Tenants
 (unmatched inbound)
 LOG Customer-Tenants → Any
 (unmatched outbound)

6.2 Policy Workspace Lifecycle

Phase	Mode	Duration	Purpose
1	Simulation	2 weeks	Validate against live traffic
2	Enforcement of cross-tenant denies	1 week	The most critical KOS rule first
3	Full Enforcement	Ongoing	Workload allowlist enforced; monthly exception review

Workspace snapshots = KOS / IDM / OPS control-implementation evidence.

7. Phase 5 — Topic Mapping with CSW Evidence

C5 topic area	What CSW produces	How to use it
AM	Workload inventory; scope + label export	Asset and classification evidence
IDM	Policy workspace + enforcement / violation	Workload-to-workload privilege evidence

C5 topic area	What CSW produces	How to use it
	log	(complements identity layer)
KRY	Plaintext-flow detection	Detection input only
OPS	Continuous flow / process telemetry; vulnerability + reachability; configuration drift on policy	Operational security evidence
KOS	Policy workspace; ADM-derived allowlist; observed flows	Communication security / tenant separation
SP	Outbound flow summary to service-provider endpoints	Sub-service-provider monitoring evidence
SIM	Flow + process search across the incident window	Forensic timeline
BCM	Approved flow baseline for recovery validation	Recoverability input
COM	Periodic evidence pack (Section 10.1)	Auditor work-paper input
INQ	Flow + process search	Investigation evidence

8. Phase 6 — Vulnerability & Risk Management (OPS)

Reachability-weighted prioritisation:

Priority 1: Critical CVE on Customer-Tenants with inbound reachability

Priority 2: Critical CVE on Shared-Infrastructure with reach into Customer-Tenants

Priority 3: Critical CVE on Management-Plane workloads

Document compensating controls in the policy workspace exception register; this register is itself evidence under OPS (vulnerability and risk management).

9. Phase 7 — Monitoring & Alerting (OPS / SIM)

Alert	Trigger	C5 topic
Cross-tenant attempt	Tenant-A → Tenant-B (any flow)	KOS

Alert	Trigger	C5 topic
Management-Plane → Customer-Tenant outside change window	Operator-Jump-Hosts → Customer-Tenants outside an authorised change window	IDM / OPS
External egress from Customer-Tenants	Customer-Tenants → external endpoint not in allow-list	SP / KOS
Plaintext on regulated path	HTTP / unencrypted DB protocol from Customer- Tenants	KRY (detection)
Policy violation	Enforced policy block triggered	KOS / OPS
Sensor offline	Agent stops reporting	Evidence integrity

9.2 Forensic Telemetry

Per incident, retain:

- Flow log scoped to affected workload(s) and time window (with process context)
- Process search output
- Policy workspace state at the time of the incident
- Vulnerability snapshot for the affected workload(s)
- Customer / tenant identification of the affected workload(s) for breach-notification scoping (decision is governance, not automated)

10. Reporting & Evidence Collection

10.1 Evidence per Audit Cycle (continuous; auditor sample window typically 12 months for Type 2)

Evidence item	CSW source area	C5 topic
Workload inventory	Inventory export	AM
Scope + label membership	Scope membership export	AM / KOS
Approved vs. observed flows	ADM workspace export	KOS / OPS
Policy workspace snapshot	Policy workspace export	KOS / IDM
Policy enforcement / violations	Policy analysis output	KOS / IDM / OPS
Vulnerability + reachability	Vulnerability report scoped to BSI-C5	OPS

Evidence item	CSW source area	C5 topic
Cross-tenant deny evidence	Policy workspace + violation log of cross-tenant attempts	KOS
External service-provider egress	Flow search to External-Service-Providers	SP
Incident timeline samples	Flow + process search	SIM / INQ
Exception register	Policy workspace exceptions list	OPS (risk acceptance)

10.2 Ongoing Compliance Posture

- **Monthly:** scope / inventory hygiene; tenant boundary review
- **Quarterly:** policy workspace review; refresh evidence pack 10.1
- **Annually:** independent walk-through with the C5 auditor; refresh assumptions and baselines
- **Continuously:** policy drift detection; ADM re-run every 90 days

11. Common Pitfalls

Pitfall	Mitigation
Treating CSW evidence as the full C5 attestation	C5 covers organisational, physical, supplier, and personnel controls outside CSW's scope
Tenant labels missing or inconsistent	Reconcile customer / tenant register ↔ CSW labels monthly; tenant boundary is the most important KOS evidence
Cross-tenant flows discovered late in the audit	Cross-tenant deny should be the very first enforcement rule
service_offering not aligned with the contracted offering definitions	Map service offerings 1:1 to scope branches; this is what the auditor will sample against
Plaintext assumed by port	Confirm by process + observed handshake
Treating SP egress as safe because the destination is "well-known"	All service-provider egress should be enumerated, reconciled to the SP register, and monitored

Related Frameworks in This Repository

- [ISO/IEC 27001:2022](#) — many C5-attested CSPs are also ISO 27001 certified

- [SOC 2 Type II](#) — similar attestation model and very similar evidence style
 - [GDPR](#) — relevant where C5-attested services process EU personal data
 - [NIST SP 800-53 Rev 5](#) — useful technical control reference
-

Document prepared for Cisco cloud-service-provider engagements serving German public-sector and regulated customers. Replace [Customer Name] and any bracketed fields before customer delivery. Validate topic-area and criterion references against the C5 catalogue version applicable to your attestation scope.